

# 115 年第一次資訊安全工程師-初級能力鑑定【公告試題】

## 第一科：資訊安全管理概論

考試日期：115 年 05 月 23 日

### 一、選擇題

| 答案 | 題目                                                                                                                                                        |
|----|-----------------------------------------------------------------------------------------------------------------------------------------------------------|
| B  | 1. 有一來自客戶的要求，老闆請您評估 ISO 系列的認證，身為資訊安全專業人員的您，為提供給客戶最佳的雲端服務，請問您的建議是下列何項？<br>(A) ISMS<br>(B) ISO 27017<br>(C) PIMS<br>(D) ISO 27018                           |
| C  | 2. 近來醫院個資外洩事件頻傳，身為醫療界最大龍頭，可以評估導入下列何項認證標準，以強化健康醫療資訊的資安管控？<br>(A) ISO 13485<br>(B) ISO 27011<br>(C) ISO 27799<br>(D) ISO 27036                              |
| A  | 3. 「人員」常是資通安全管理實務中最為脆弱及難以掌控的突破口。企業建立資通安全管理制度時，通常會在人員入職前、在職中及離職後等階段設置相關管理措施。依據上述情境，下列何者較「不」屬於人員安全管理措施？<br>(A) 考勤管理<br>(B) 職務區隔<br>(C) 盡職調查<br>(D) 認知及宣導    |
| A  | 4. 某軟體服務商在其公司官網上，定期公告所販售的應用軟體安全性更新檔案供使用者下載，並在下載頁面上同時提供檔案的雜湊值（如 SHA-256 值、SHA-512 值）。此行為主要目的是實現資通安全的下列哪一項觀念？<br>(A) 完整性<br>(B) 可用性<br>(C) 機密性<br>(D) 不可否認性 |

# 115 年第一次資訊安全工程師-初級能力鑑定【公告試題】

## 第一科：資訊安全管理概論

考試日期：115 年 05 月 23 日

| 答案 | 題目                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|----|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| D  | <p>5. 某金融科技公司正在導入 ISO/IEC 27001:2022 資訊安全管理系統 (ISMS)。資訊安全主管要求團隊對公司資訊系統進行風險評鑑。團隊首先建立風險接受準則與評鑑方法，接著識別可能影響系統機密性、完整性與可用性的風險，例如資料外洩或系統中斷，並指定各風險的負責人。之後再評估風險發生的可能性與可能造成的影響，據此判定風險等級，並依據風險準則決定優先處理的風險。依據 ISO/IEC 27001:2022 第 6.1.2 條「資訊安全風險評鑑」的要求，上述作法最符合下列哪一項說明？</p> <p>(A) 依據各部門主管的經驗判斷可能風險，並由管理階層決定是否需要處理風險</p> <p>(B) 針對過去曾發生的資安事件進行檢討，以作為未來資訊安全風險管理的主要依據</p> <p>(C) 先導入資訊安全技術控制措施，例如防火牆與加密機制，再評估其對降低風險的效果</p> <p>(D) 建立風險準則，識別與分析資訊安全風險，評估風險等級並決定風險處理優先順序</p> |
| A  | <p>6. 在進行 ISO 27001 內部稽核時，下列何者最「不」正確？</p> <p>(A) 稽核重點應該放在符合性檢查，確保所有政策和程序都符合 ISO 27001 標準，無須參考利害關係人議題</p> <p>(B) 稽核時專注於稽核表的每個細節，逐項對照檢查是否符合 ISO 標準的要求</p> <p>(C) 稽核頻率可根據風險評估結果靈活安排，並不局限於每年一次的檢查</p> <p>(D) 高階主管為表達支持，要求各部門主管擔任內稽，因為主管最清楚部門內的作業流程和風險</p>                                                                                                                                                                                                        |
| B  | <p>7. 某公司為履行契約而蒐集並持有甲君之個人資料。依《個人資料保護法》第 3 條規定，甲君得向該非公務機關行使個資主體之權利。下列何者為錯誤的權利敘述？</p> <p>(A) 請求停止蒐集、處理或利用</p> <p>(B) 請求製給正本</p> <p>(C) 查詢或請求閱覽</p> <p>(D) 請求補充或更正</p>                                                                                                                                                                                                                                                                                          |
| D  | <p>8. 下列何者「不」屬於特種個資？</p> <p>(A) 病歷</p> <p>(B) 健康檢查</p> <p>(C) 性生活</p> <p>(D) 指紋</p>                                                                                                                                                                                                                                                                                                                                                                          |

《以下空白》

# 115 年第一次資訊安全工程師-初級能力鑑定【公告試題】

## 第一科：資訊安全管理概論

考試日期：115 年 05 月 23 日

| 答案 | 題目                                                                                                                                                                                                                          |
|----|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| C  | 9. 特定非公務機關若因業務需求且無其他替代方案，專案欲使用危害國家資通安全產品，下列有關其申請程序之敘述，何者正確？<br>(A) 該機關資訊長可自行核定後使用，但需列冊管理<br>(B) 經該機關首長同意，函報主管機關核定<br>(C) 經該機關資通安全長核可，函報中央目的事業主管機關核定<br>(D) 經該機關資訊長核可，函報主管機關核定                                               |
| D  | 10. 公務機關對所屬資通安全專職人員進行適任性查核，若經查核認定有「不適任」之情事時，該機關應採取下列何種處置？<br>(A) 立即送交主管機關進行懲處<br>(B) 立即終止其專職人員資格，並禁止其辦理任何資通安全業務<br>(C) 應予解職或調離職務<br>(D) 不得辦理涉及國家機密、軍事機密及國防秘密之資通安全業務                                                         |
| D  | 11. 請問下列何者「不」是營業秘密法第二條所述符合營業秘密之要件？<br>(A) 所有人已採取合理之保密措施者<br>(B) 因其秘密性而具有實際或潛在之經濟價值者<br>(C) 非一般涉及該類資訊之人所知者<br>(D) 受雇人於職務上研究或開發之營業秘密，須歸雇用人所獨有                                                                                 |
| D  | 12. 某線上購物平台發現內部員工可能將客戶聯絡資訊下載到個人電腦中，用於私人行銷。公司資訊安全小組必須決定應採取的行動，下列行動何者最為適切？<br>(A) 僅提醒員工不要將資料帶出公司，並依賴其自律<br>(B) 將員工行為視為例外，暫時不做任何改變，觀察是否真的造成問題<br>(C) 將資料全數刪除，暫停會員服務，直到確認無資料外洩疑慮為止<br>(D) 限制資料存取權限，並建立系統紀錄與警示機制，以防止未授權存取        |
| A  | 13. 某線上社交平台希望利用使用者資料進行大數據分析，但資料可能包含敏感個資。公司所採取的做法下列何者最為適切？<br>(A) 去識別化資料後進行分析，並定期評估是否仍可能重新識別個人<br>(B) 直接使用原始資料進行分析，提高分析精度，但不做任何匿名處理<br>(C) 將所有資料提供給外部廣告公司，依賴其自行處理<br>(D) 將資料庫的連線全面採用 TLS 加密傳輸，並啟用存取控制，即可在不影響隱私的前提下開放存取原始明文資料 |

《以下空白》

# 115 年第一次資訊安全工程師-初級能力鑑定【公告試題】

## 第一科：資訊安全管理概論

考試日期：115 年 05 月 23 日

| 答案 | 題目                                                                                                                                                                                                       |
|----|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| B  | 14. ISO/IEC 27001 針對資訊資產的管理事項，其中一個是資訊分類（級）（Classification）並對資訊完成其敏感性等級的定義。下列哪一項為最有可能負責資訊敏感性等級定義的角色？<br>(A) 保管人（Custodian）<br>(B) 擁有者（Owner）<br>(C) 查核員（Auditor）<br>(D) 使用者（User）                         |
| C  | 15. 在資訊安全管理系統（ISMS）的執行流程中，「盤點資訊資產」通常是位於下列哪一個階段？<br>(A) 執行風險處理計畫之後<br>(B) 驗證稽核之後<br>(C) 定義 ISMS 適用範圍之後，執行資通安全風險評鑑之前<br>(D) 管理審查會議後，下次外部稽核前執行                                                              |
| D  | 16. 在落實資訊安全管理制度（ISMS）時，行銷部門主管認為「客戶名單」屬於機密資料，但 IT 管理員認為該檔案僅供內部參考。在資產分類的權責架構中，較「不」適合由下列何者決定該資料的機密等級？<br>(A) 資訊資產擁有者（Asset Owner）<br>(B) 資訊安全長（CISO）<br>(C) 資料隱私保護官（DPO）<br>(D) 系統管理員（System Administrator） |
| B  | 17. 關於資訊資產的「盤點與評鑑」責任，係由下列哪一個層級或組織負責較為合適？<br>(A) 由高階管理人員負責<br>(B) 由跨部門之風險評鑑組織中的「資安執行小組」負責<br>(C) 由業務承辦人負責<br>(D) 由資訊單位或資安人員負責                                                                             |
| D  | 18. 軟體資產盤點中的「軟體物料清單（Software Bill of Materials, SBOM）」，其主要功能是用於盤點下列何項資產屬性？<br>(A) 使用者的存取紀錄與行為模式<br>(B) 軟體的授權費用與到期日<br>(C) 伺服器的硬體規格與效能指標<br>(D) 軟體組成中的第三方元件與開源函式庫版本                                       |

# 115 年第一次資訊安全工程師-初級能力鑑定【公告試題】

## 第一科：資訊安全管理概論

考試日期：115 年 05 月 23 日

| 答案 | 題目                                                                                                                                                                                                           |
|----|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| C  | 19. 資安團隊發現員工為了提升效率，私下將公司程式碼上傳至未經核准的 AI 生成工具（如 ChatGPT）。在制定阻擋策略之前，為了有效管理此類「影子 IT（Shadow IT）」風險，首要執行的步驟下列何項最為適切？<br>(A) 強制重灌所有員工的電腦<br>(B) 立即封鎖所有對外的網路連線<br>(C) 執行軟體與雲端服務的資產盤點（Inventory）<br>(D) 要求所有員工簽署離職切結書 |
| D  | 20. 資料（DATA）常為資訊資產類型的其中一項，完成資料盤點後應明瞭其生命週期及運作階段，並進而在各階段設計可採用的保護措施。關於「資料傳遞」及對應運用之安全協定配對，下列哪一項錯誤？<br>(A) 檔案傳輸：FTPS<br>(B) 網頁傳輸：HTTPS + TLS<br>(C) 電子郵件傳送：SMTPS<br>(D) 遠端連線 Shell：SFTP                           |
| B  | 21. 某企業完成資訊安全風險評鑑後，發現多項風險，包括系統漏洞、弱密碼問題及資料備份不足。資訊安全團隊依據公司事先建立的風險接受準則，比較各項風險的分析結果，並決定優先處理的項目。上述作法最符合資訊安全風險管理中的下列哪一個步驟？<br>(A) 建立資訊安全教育訓練制度<br>(B) 評估風險並決定風險處理順序<br>(C) 建立資訊安全政策文件<br>(D) 建立風險評鑑清冊              |
| A  | 22. 下列何項是評估資通系統安全等級的主要影響構面？<br>(A) 機密性、完整性、可用性、法律遵循性<br>(B) 資產價值、成本效益、時效性、法規遵循性<br>(C) 威脅、弱點、衝擊、可能性<br>(D) 硬體、軟體、場域、人員                                                                                       |

《以下空白》

# 115 年第一次資訊安全工程師-初級能力鑑定【公告試題】

## 第一科：資訊安全管理概論

考試日期：115 年 05 月 23 日

| 答案 | 題目                                                                                                                                                                                                                                                                                  |
|----|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| B  | 23. 某電力公司發現控制中心主伺服器若遭惡意軟體攻擊，可能導致停電事故。經評估後，公司決定導入網段隔離與惡意程式偵測系統，以降低攻擊成功的可能性。此舉屬於下列何種風險處理（Risk Treatment）方式？<br>(A) 風險避免（Risk Avoidance）<br>(B) 風險降低（Risk Reduction）<br>(C) 風險接受（Risk Acceptance）<br>(D) 風險轉移（Risk Transfer）                                                           |
| D  | 24. 在資訊及資通系統之「詳細風險評鑑作法」中，用來計算「風險值」並最終決定「風險等級」，下列何項是風險值計算的主要因素？<br>(A) 資通安全責任等級、資安事件分級、業務活動說明<br>(B) 現有控制措施、衝擊準則、風險接受準則<br>(C) 機密性、完整性、可用性、法律遵循性<br>(D) 資產價值、威脅發生可能性、弱點利用難易度                                                                                                         |
| B  | 25. 公司選定 NIST 風險管理框架（Risk Management Framework, RMF）作為風險管理框架。身為一名資安人員，你已完成風險評估，接下來應該做下列何項步驟？<br>(A) Framing risk（界定風險）<br>(B) Responding risk（應對風險）<br>(C) Monitoring risk（監控風險）<br>(D) Asset Inventory（盤點資訊資產）                                                                     |
| C  | 26. 某雲端服務商在使用者連續多次登入失敗後，下列何項處置最為適切？<br>(A) 立即刪除帳號<br>(B) 無需任何限制<br>(C) 鎖定並限制登入間隔時間<br>(D) 僅記錄失敗次數                                                                                                                                                                                   |
| B  | 27. 在實施零信任架構（ZTA）時，傳統的靜態授權（如 Role-based Access Control, RBAC）已不足以應對動態威脅。現代存取控制策略轉向「基於屬性的存取控制（Attribute-based access control, ABAC）」。下列何者最能體現 ABAC 的決策邏輯？<br>(A) 使用者可以自行決定將檔案分享給誰<br>(B) 只有在上班時間、使用公司配發電腦且來自台灣 IP 的請求，才允許存取<br>(C) 因為你是經理，所以你可以存取人資系統<br>(D) 系統依據機密標籤強制比對，禁止低權限讀取高機密 |

《以下空白》

# 115 年第一次資訊安全工程師-初級能力鑑定【公告試題】

## 第一科：資訊安全管理概論

考試日期：115 年 05 月 23 日

| 答案 | 題目                                                                                                                                                                                                                                                                                      |
|----|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| B  | 28. 隨著生成式 AI 能輕易製作逼真的 Deepfake 影片與高解析度照片，生物辨識系統面臨「呈現攻擊（Presentation Attack）」的風險。為了確保掃描的是真實的人體而非照片或模型，採購系統時必須要求具備下列何項功能？<br>(A) 更高的解析度採樣（High Resolution Sampling）<br>(B) 活力（體）檢測（Liveness Detection / PAD）<br>(C) 快速比對演算法（Fast Matching Algorithm）<br>(D) 多模態生物特徵儲存（Multimodal Storage） |
| B  | 29. 軟體開發團隊正在導入自動化 CI/CD 流程，應用程式需頻繁存取後端資料庫。為了避免將憑證寫死在程式碼中（Hardcoded Credentials），下列何項驗證策略最為適切？<br>(A) 關閉資料庫的身分驗證功能，改用 IP 白名單進行控管<br>(B) 使用工作負載身分同盟（Workload Identity Federation）或託管身分，透過短憑證進行驗證<br>(C) 將資料庫密碼加密（Password encryption）後儲存於原始碼的版本控制系統中<br>(D) 設定極為複雜的資料庫密碼並每半年手動更換一次        |
| D  | 30. 為了落實最小權限原則並消除「常設性管理員權限（Standing Privileges）」帶來的風險，現代特權存取管理（Privileged Access Management, PAM）傾向採用「即時存取（Just-in-Time, JIT）」策略。下列何者最符合 JIT 的運作模式？<br>(A) 管理員擁有永久帳號，但每 90 天強制換密碼<br>(B) 使用共用的高權限帳號並存放在保險箱中<br>(C) 將所有管理員權限分割給不同的人（職責分離）<br>(D) 權限平時為零，僅在核准的工單期間內動態賦予權限，用完即收回           |
| C  | 31. 關於最小權限原則（Principle of Least Privilege）的主要目的，下列哪一項最為適切？<br>(A) 依據使用者所屬部門給予統一的存取權限<br>(B) 接受系統預先定義之權限<br>(C) 限制使用者僅能存取完成工作所需的資源<br>(D) 確保系統管理者擁有系統管理所需資源存取權限                                                                                                                          |
| C  | 32. 企業導入零信任架構（Zero Trust Architecture）時，下列哪一項較為正確？<br>(A) 建立網路邊界防護後，即可預設信任內部網路的所有使用者與設備<br>(B) 依據所屬的部門或職級，給予對內部所有資源的存取權限<br>(C) 無論存取來源為何，所有存取請求都經過持續的驗證與動態授權<br>(D) 首次登入系統並通過多因子驗證後，該次連線期間即不需再次進行驗證                                                                                     |

# 115 年第一次資訊安全工程師-初級能力鑑定【公告試題】

## 第一科：資訊安全管理概論

考試日期：115 年 05 月 23 日

| 答案 | 題目                                                                                                                                                                                                                    |
|----|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| C  | 33. 某企業要求員工登入 VPN 時必須輸入密碼並使用手機 OTP 驗證碼。此措施主要是基於下列哪一項因素？<br>(A) 知識因素 (Something you know)<br>(B) 生物特徵因素 (Something you are)<br>(C) 持有因素 (Something you have)<br>(D) 行為因素 (Something you do)                            |
| A  | 34. 某企業導入雲端人資系統，允許外包廠商在專案期間查詢部分員工資料。專案結束後，資訊部門忘記回收廠商帳號，半年後該帳號仍可登入系統。若從「管理面」優先改善，最有效的措施為下列哪一項？<br>(A) 將帳號存取權限與需求連動<br>(B) 強制外包帳號使用多因素驗證<br>(C) 增加登入失敗次數限制<br>(D) 將密碼有效期限縮短                                             |
| A  | 35. 某電商平台為因應日益嚴重的社交工程威脅，擬導入具備「抗網路釣魚 (Phishing-Resistant)」特性之身分認證機制，以防止使用者於偽造的釣魚網站輸入憑證。下列何項認證技術最「不」適切？<br>(A) 靜態密 (恢復) 碼 (Recovery Codes)<br>(B) 快速線上身分驗證 (FIDO2)<br>(C) 簡訊動態密碼 (SMS OTP)<br>(D) 基於時間的動態密碼 (TOTP)      |
| A  | 36. 關於公開金鑰加密 (Public-key encryption) 的主要特性，下列何項描述最為適切？<br>(A) 允許不共享秘密金鑰 (Secret key) 的兩方，進行安全通訊<br>(B) 使用相同秘密金鑰 (Secret key) 進行加解密，因此更簡單<br>(C) 加解密速度比對稱金鑰加密 (Symmetric-key encryption) 更快<br>(D) 不需要任何金鑰生成演算法，因此效能更好 |
| D  | 37. 在資通安全的三大核心防護目標 (CIA) 中，採用「資料加解密」這種保護措施，最主要的作用是為了確保下列哪一項資訊資產的特性？<br>(A) 完整性 (Integrity)<br>(B) 法律遵循性 (Legal compliance)<br>(C) 可用性 (Availability)<br>(D) 機密性 (Confidentiality)                                     |

《以下空白》

# 115 年第一次資訊安全工程師-初級能力鑑定【公告試題】

## 第一科：資訊安全管理概論

考試日期：115 年 05 月 23 日

| 答案 | 題目                                                                                                                                                                                                                                                     |
|----|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| C  | 38. 關於雜湊函式 (Hash Function)，下列敘述何者正確？<br>(A) 雜湊函式主要用於資料傳輸時的機密性保護<br>(B) 雜湊函式演算法安全性導因於解離散對數的困難度<br>(C) 雜湊函式可將任何長度的資料轉換成固定長度的訊息特徵值<br>(D) 雜湊值可以透過解密方式還原為原始訊息，具有可逆性                                                                                        |
| A  | 39. 為有效防範「預運算雜湊攻擊」(如彩虹表攻擊)，並確保相同密碼在系統中產生的雜湊值具有唯一性，系統通常會在執行雜湊運算前，於明文密碼中加入一段隨機產生的唯一字串，下列哪一項是此種技術於密碼學領域之專業術語？<br>(A) 鹽值 (Salt)<br>(B) 憑證 (Certificate)<br>(C) 數位信封 (Digital Envelope)<br>(D) 訊息摘要 (Message Digest)                                        |
| C  | 40. 某企業為確保發布於官網的軟體更新檔在傳輸過程中未遭惡意竄改，擬提供該檔案的「數位摘要 (Message Digest)」供使用者比對驗證。此技術必須具備「無法反推原始檔案內容」的單向特性，下列何項技術最適切？<br>(A) 數位簽章 (Digital Signature)<br>(B) 對稱式加密 (Symmetric Encryption)<br>(C) 雜湊函數 (Hash Function)<br>(D) 非對稱式加密 (Asymmetric-Key Encryption) |
| B  | 41. 某企業的供應鏈廠商遭受網路攻擊，導致企業的資料外洩。下列何措施最能降低供應鏈風險？<br>(A) 選擇報價最便宜的供應商<br>(B) 對供應商進行資安評估和審查<br>(C) 限制與供應商的資料共享<br>(D) 將所有供應鏈管理工作外包                                                                                                                           |
| D  | 42. 依據 NIST SP 800-61 所描述之「資安事件處理生命週期」，下列何項為第二階段偵測與分析 (Detection and Analysis) 的任務之一？<br>(A) 隔離受影響主機、移除惡意程式並修補弱點<br>(B) 檢討並改善缺失，避免後續類似事件再度發生<br>(C) 封鎖並排除發生事件的根本原因後恢復正常運作<br>(D) 依觀測到的跡證進行影響範圍界定與嚴重度分級                                                 |

# 115 年第一次資訊安全工程師-初級能力鑑定【公告試題】

## 第一科：資訊安全管理概論

考試日期：115 年 05 月 23 日

| 答案 | 題目                                                                                                                                                                                       |
|----|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| B  | 43. 在資安事件處理程序中，下列哪一項是「封鎖」階段的首要目標？<br>(A) 立即恢復所有業務運作<br>(B) 限制事件擴散範圍，阻止損害進一步蔓延<br>(C) 徹底移除所有惡意程式<br>(D) 對攻擊者提起法律訴訟                                                                        |
| A  | 44. 公務機關判定資通安全事件等級時，應衡酌機密性、完整性及可用性（CIA）之受損影響程度。若某事件經評估後，其影響等級分別為「機密性受損：2 級」、「完整性受損：3 級」、「可用性受損：1 級」，則該事件最終應判定為幾級資通安全事件？<br>(A) 第 3 級<br>(B) 第 1 級<br>(C) 第 2 級<br>(D) 由資訊主管自行決定          |
| B  | 45. 在資通安全事件處理的「根除階段」，若評估受感染系統存在高隱匿性惡意程式（如 Rootkit），且無法確保能完全清除潛伏之殘留威脅時，下列何者為較安全的處置方式？<br>(A) 僅更換防毒軟體品牌後繼續使用<br>(B) 採回存方式，從乾淨備份還原或全新安裝系統<br>(C) 增加防火牆規則阻擋該主機 IP<br>(D) 暫時不處理，改採持續監控        |
| A  | 46. 以下何者是異地備援的主要目的？<br>(A) 避免單一地域的災難影響<br>(B) 簡化系統的備份流程<br>(C) 降低資料傳輸的延遲<br>(D) 提高系統的即時效能                                                                                                |
| C  | 47. 關於營運持續管理（Business Continuity Management, BCM）的責任歸屬，下列何項敘述最為正確？<br>(A) 營運持續管理僅需由安全部門負責規劃與執行<br>(B) 營運持續管理主要是資訊部門的責任<br>(C) 營運持續管理必須由核心業務所有相關部門共同投入<br>(D) 營運持續管理是高階管理人員的專屬職責，其他部門只需配合 |

《以下空白》

# 115 年第一次資訊安全工程師-初級能力鑑定【公告試題】

## 第一科：資訊安全管理概論

考試日期：115 年 05 月 23 日

| 答案 | 題目                                                                                                                                                                                                                                                                                                                                                                                    |
|----|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| D  | 48. 某機關的備份策略為：週一執行「完整備份」，週二至週四執行「增量備份」。若該機關於週五上班前發生系統潰散，需進行資料還原，下列關於還原程序之敘述，何者正確？<br>(A) 僅需還原週一的完整備份<br>(B) 還原週一完整備份 + 週四的備份<br>(C) 僅需還原週四的備份<br>(D) 還原週一完整備份 + 週二、週三、週四的備份                                                                                                                                                                                                           |
| C  | 49. 在業務持續運作管理程序中，組織在進行「營運衝擊分析 (BIA)」以識別核心業務及其復原時效需求前，通常應先完成下列哪一項階段性工作？<br>(A) 發展復原策略<br>(B) 維護營運持續計畫<br>(C) 建立業務持續運作策略<br>(D) 測試與演練                                                                                                                                                                                                                                                   |
| A  | 50. 在制定營運持續計畫 (BCP) 的時間目標時，為確保各項復原目標的合理性，下列哪一項為絕對「不」可違背的邏輯限制？<br>(A) RTO (Recovery Time Objective) 不可大於 MTPD (Maximum Tolerable Period of Disruption)<br>(B) WRT (Work Recovery Time) 必須小於 RPO (Recovery Point Objective)<br>(C) MTPD (Maximum Tolerable Period of Disruption) 必須小於 RTO (Recovery Time Objective)<br>(D) RPO (Recovery Point Objective) 不可大於 WRT (Work Recovery Time) |

《以下空白》